Risk analysis and management for ICT systems

Introduction to risk management methodology, juridical aspects and case studies

Stefano Zatti and Raffaele Gargiulo

DIPARTIMENTO
DI INFORMATICA



SAPIENZA
UNIVERSITÀ DI ROMA

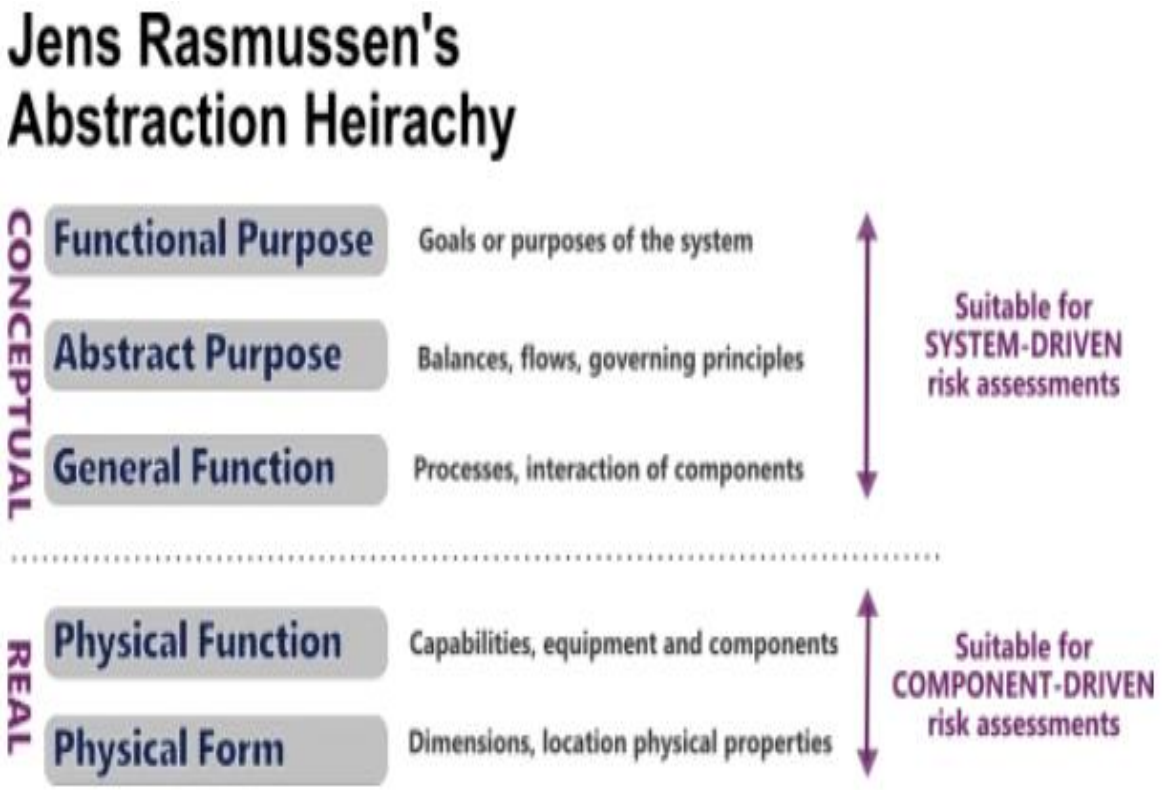
Risk analysis and management (ZATTI)

1. Introduction. The ISO 27000 family of standards
2. The ISO 27005 standard for management of information technology risks
3. Similar standards: NIST 800-30
4. Methodologies: EBIOS, Octave ...
5. The threat profile from ENISA
6. The implementation of the ISMS - how to start a project - phases of risk assessment
7. Asset inventory and scope definition. Threats and vulnerabilities
8. Risk evaluation, risk treatment, countermeasures, communication
9. Case study: the corporate ICT system
10. Case study: Cyber security of Space Missions

What is Risk Assessment?

- **ISO 27005** Risk Assessment = Identification, Estimation and Evaluation (2)
- **NIST SP 800-30 (3)**
  Risk Assessment is the analysis of threats in conjunction with vulnerabilities and existing controls.
- **EBIOS -** today
- **OCTAVE –** today
- **Start from Jens Rasmussen's model**: an abstract model to distinguish risk assessment techniques

Using Rasmussen's model: A hierarchy to distinguish risk assessment techniques



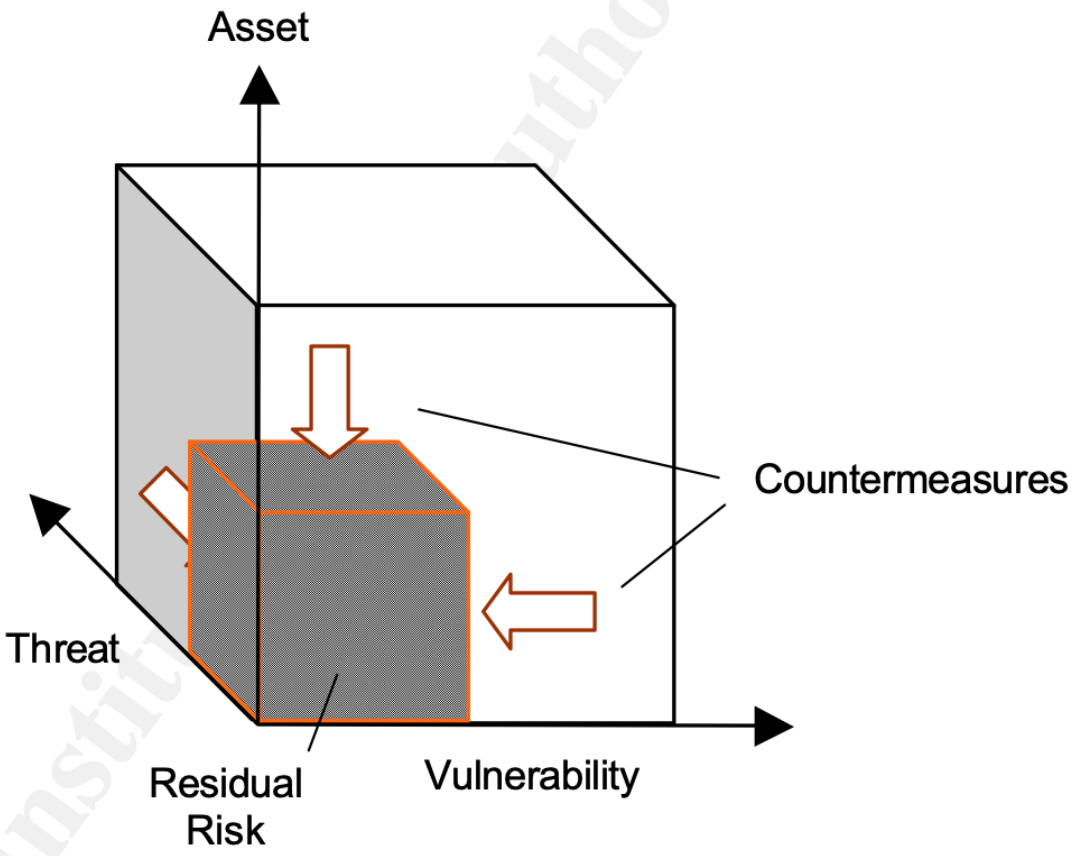
- This model introduces the idea that you can look at systems at different levels of abstraction. Considering just the top three layers of illustration allows us to think about the system in *conceptual terms.* That is, we're focusing our analysis on **what** should be achieved by the system (rather than **how** it should work). Component-driven techniques are about analysing what could go wrong at the bottom two layers of this hierarchy. They are concerned with things that physically exist, or their representations, such as detailed architecture diagrams detailing specific technology decisions.
- System-driven techniques consider the system's high-level purpose and functions. The aim is to identify ways in which losses could be realised, as a consequence of the conceptual design of your system. At this level of abstraction, threat and vulnerability, as they are used in component-driven methods, don't make sense. We are looking for ways in which the system could suffer any negative impact.

What are they good for?

	Good for
Component-driven methods	• Analysing the risks faced by individual technical components. • Deconstructing less complex systems, with well-understood connections between component parts. • Working at levels of abstraction where a system's physical function has already been agreed amongst stakeholders.
System-driven methods	• Exploring security breaches which emerge out of the complex interaction of many parts of your system. • Establishing system security requirements before you have decided on the system's exact physical design. • Bringing together multiple stakeholders' views of what a system should and should not do (eg safety, security, legal views). • Analysing security breaches which cannot be tracked back to a single point of failure.

The risk assessment cube

Risk = Asset x Threat x Vulnerability



Risk Assessment reference points

- ISO 31000
- ISO 27005
- NIST SP 800-30
- OCTAVE – Carnegie Mellon University - Operationally Critical Threat, Asset, and Vulnerability Evaluation
- EBIOS – *Étude des Besoins et Identification des Objectifs de Sécurité,* allows evaluation and action on risks relative to information systems security, and proposes a security policy adapted to the needs of an organization. This risk analysis method has been created by the DCSSI (Direction Centrale de la Sécurité des Systèmes d'Information), a department of the French Ministry of Defense. *System driven*
- Mehari(MEthod for Harmonized Analysis of RIsk), from CLUSIF - France
- CRAMM (CCTA Risk Analysis and Management Method) from the UK cabinet office
- Magerit, from the Ministerio de Administraciones Publicas of Spain

Risk Assessment reference points

- ISO 31000
- ISO 27005
- OCTAVE
- NIST SP 800-30
- EBIOS – system driven
- Mehari
- CRAMM
- Magerit

What is EBIOS?

ANSSI Agence nationale de la sécurité des systèmes d'information

EBIOS is the French acronym for “Expression of Needs and Identification of Security Objectives”. It is a risk management method related to information systems security (also known as INFOSEC). It was created in 1995 by the Central Service for the Security of Information Systems (SCSSI), the former name of the ANSSI (National Agency for the Security of Information Systems), which now maintains it..

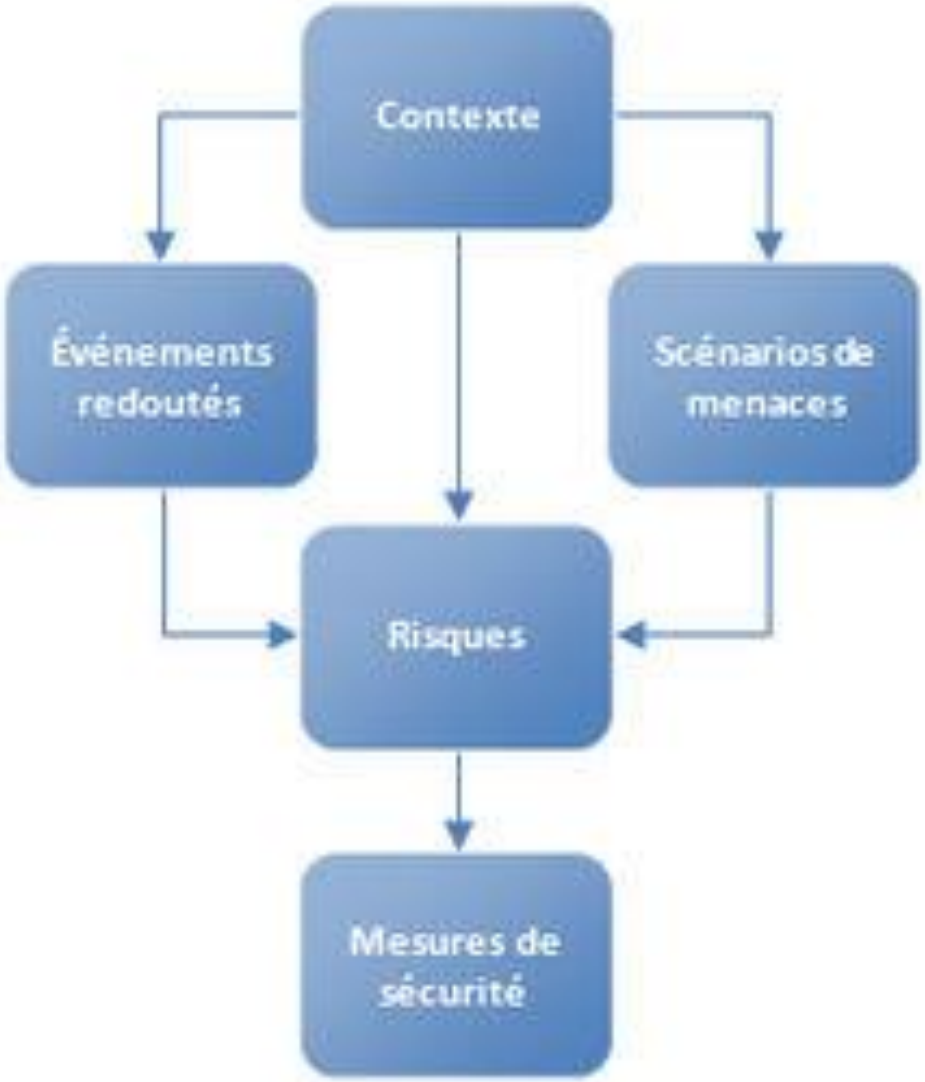
Objectives

The methodology is structured in the following goals:

- provide a common base of concepts and practical activities for anyone involved in risk management, particularly for information security.
- satisfy the needs for the risk management of an ISMS, an information security management system ([ISO 27001]).
- define a complete methodological approach that is consistent and in accordance with risk management international standards ([ISO 31000], [ISO 27005]…).
- set up a reference for risk management skills certification.

EBIOS is a trademark submitted by the General Secretariat for Defence and National Security (SGSDN) of France

Modules of EBIOS methodology



Where can you find EBIOS?

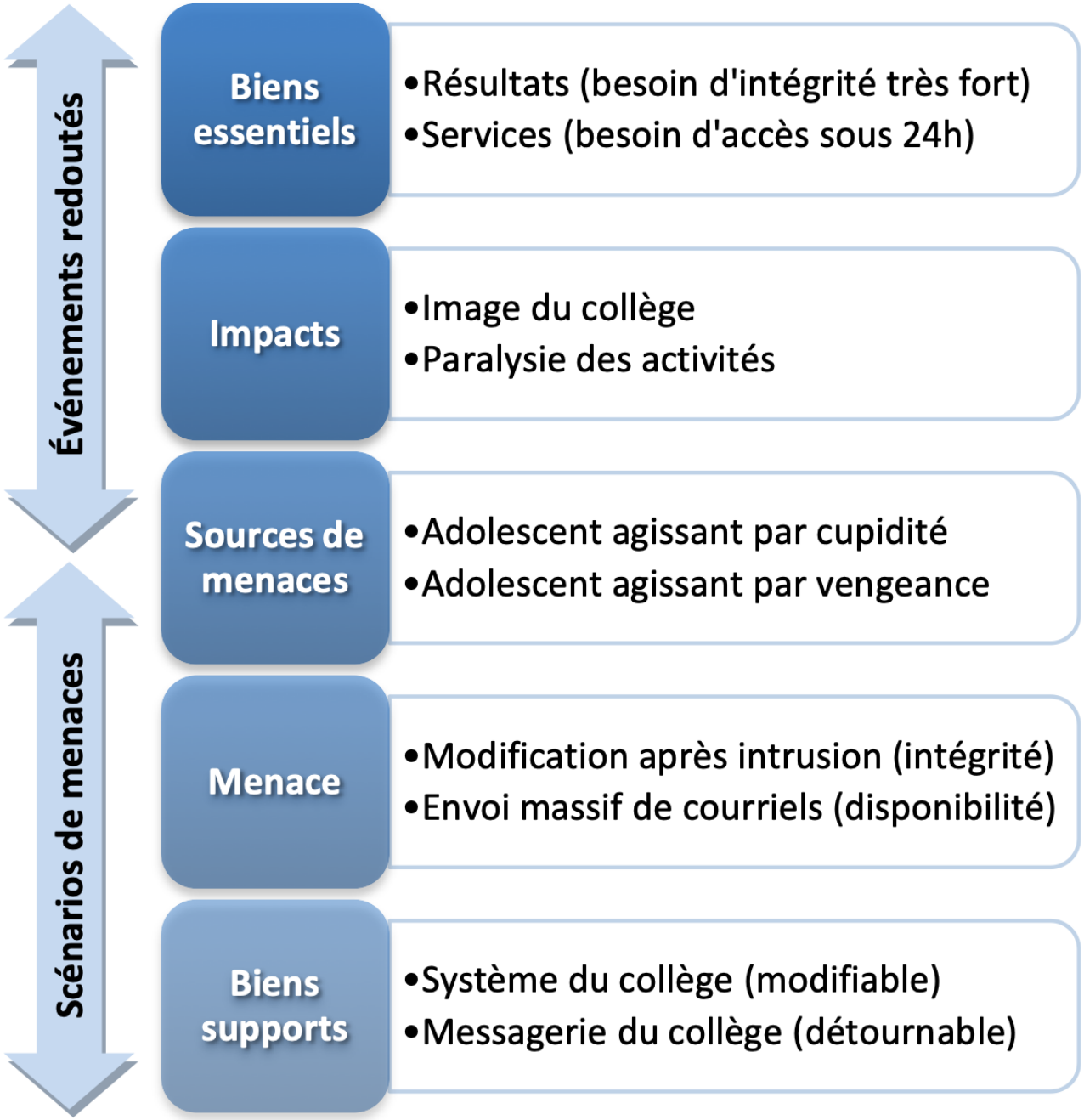
- https://www.ssi.gouv.fr/guide/ebios-2010-expression-des-besoins-et-identification-des-objectifs-de-securite/

The feared event scenario

Un adolescent de 15 ans « pirate » le système informatique de son collège pour améliorer ses notes.

Un adolescent de quinze ans a en effet été interpellé pour s'être introduit dans le système informatique de son collège dans le but de modifier ses résultats scolaires. Dépité de n'avoir pu atteindre ce but, le collégien a saturé le système informatique en expédiant plus de 40 000 courriels, manœuvre qui a provoqué une indisponibilité pendant quatre jours.

[Sources Internet : Le Point.fr et ZDNet]



Risque 1

Altération des résultats

Un adolescent agissant par cupidité s'introduit dans le système du collège et modifie ses résultats, qui doivent rester parfaitement intègres, ce qui ternit l'image du collège.

Risque 2

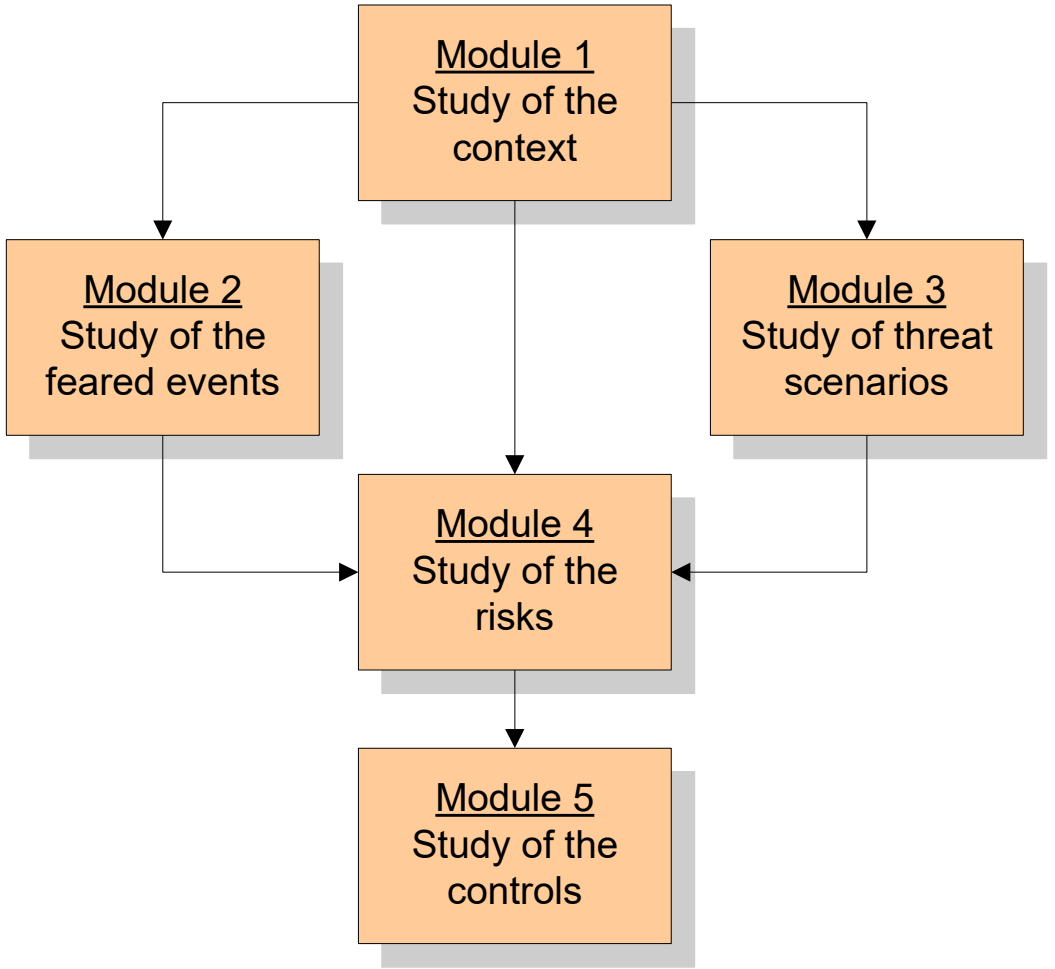
Indisponibilité des services

Par vengeance, un adolescent sature la messagerie par un envoi massif de courriels, ce qui bloque les services du collège et paralyse ses activités.

The toolbox to convince management



An iterative approach in five steps



Method

- When managing information security risks, a methodological approach also means:
- establishing the context by taking into account its specific features (internal and external context, the issues, constraints, metrics, etc.),
- assessing the risks (identifying them in terms of feared events and threat scenarios, estimating and evaluating them),
- treating the risks (choosing the treatment options for the security objectives, determining the appropriate controls and implementing them),
- accepting the risks (formally validating the risk treatment plan and the residual risks),
- communicating about the risks (obtaining the necessary information, presenting the results, obtaining decisions and ensuring the controls are applied);
- monitoring the risks (ensuring that the feedback and changes in context are taken into account as part of the management of risk, assessed risks and controls).

Definition of respective roles

EBIOS activities	Director	Assistant director	Monitoring committee	Secretariat	Sales department	Design office	Accounts department	Documents to be produced in addition to the risk analysis	Special instructions	Estimated resources (in man/days)	Duration (in days)
Activity 1.1 – Define the risk management framework		D	C	I	I	I	I			2	2
Activity 1.2 – Prepare the metrics		D	C	I	I	I	I		Ensure uniformity of understanding	2	2
Activity 1.3 – Identify the assets	A	D	C	C	C	C	I	Context note	Do not go into too many details	6	2
Activity 2.1 – Assess the feared events		D	C	C	C	C	I		Use generic databases	6	2
Activity 3.1 – Assess the threat scenarios		D	C	C	C	C	I		Use generic databases	6	2
Activity 4.1 – Assess the risks		D	C	I	I	I	I			1	1
Activity 4.2 – Identify the security objectives	A	D	C	I	I	I	I	Strategy note		2	1
Activity 5.1 – Formalise the controls to be implemented	A	D	C	C	C	C	I	Information security policy		15	3
Activity 5.2 – Implement the controls	A	D	I	C	C	C	I	Accreditation	This activity will not be performed immediately	0	0

Key: D = Do, A = Approve, C = Consult, I = Inform

Identification of feared events

Feared event	Sensitivity	Threat sources	Impacts	Consequences
Establish the estimates				
Unavailability of estimates	24-72 hours	✓ Unprofessional employee ✓ Fire on the premises ✓ Power failure	✓ Impossible to sign contract ✓ Loss of a contract ✓ Loss of credibility	2. Limited
Alteration of estimate	Uncorrupted	✓ Unprofessional employee	✓ Impossible to sign contract ✓ Loss of a contract ✓ Impossible to fulfil legal obligations ✓ Loss of credibility	3. Important
Compromising of estimate	Limited	✓ Unprofessional employee ✓ Competitor	✓ Loss of a contract ✓ Legal proceedings against the company ✓ Loss of credibility	3. Important
Produce plans and perform the structural analysis				
• Unavailability of plans or structural analyses	24-72 hours	✓ Unprofessional employee ✓ Non-targeted virus ✓ Cleaning staff (bribed) ✓ Maintenance personnel ✓ Electricity failure	✓ Loss of credibility	2. Limited
• Alteration of drawings or structural analyses	Uncorrupted	✓ Unprofessional employee ✓ Competitor	✓ Impossible to fulfil legal obligations ✓ Loss of credibility ✓ Legal proceedings against the company ✓ Loss of reputation ✓ Dangerous situation created (building that collapses)	4. Critical
• Compromising of plans or structural analyses	Limited	✓ Unprofessional employee ✓ Cleaning staff (bribed) ✓ Maintenance personnel	✓ Loss of a contract ✓ Loss of credibility ✓ Loss of reputation ✓ Impossible to fulfil legal obligations (if contractual)	3. Important
Create visual representations				
• Unavailability of visual representations	24-72 hours	✓ Unprofessional employee ✓ Non-targeted virus ✓ Fire on the premises ✓ Electricity failure	✓ Negative rumours spread ✓ Loss of credibility ✓ Loss of reputation	2. Limited
• Alteratio				

n of drawings or structural analyses	Uncorrupted	✓ Unprofessional employee ✓ Competitor	✓ Impossible to fulfil legal obligations ✓ Loss of credibility ✓ Legal proceedings against the company ✓ Loss of reputation ✓ Dangerous situation created (building that collapses)	4. Critical
• Compromising of plans or structural analyses	Limited	✓ Unprofessional employee ✓ Cleaning staff (bribed) ✓ Maintenance personnel	✓ Loss of a contract ✓ Loss of credibility ✓ Loss of reputation ✓ Impossible to fulfil legal obligations (if contractual)	3. Important
Create visual representations				
• Unavailability of visual representations	24-72 hours	✓ Unprofessional employee ✓ Non-targeted virus ✓ Fire on the premises ✓ Electricity failure	✓ Negative rumours spread ✓ Loss of credibility ✓ Loss of reputation	2. Limited
• Alteration of visual representations	Detectable	✓ Unprofessional employee	✓ Negative rumours spread ✓ Loss of credibility ✓ Loss of reputation	2. Limited
• Compromising of visual representations	Public	-	-	1. Negligible
Manage the contents of the website				
• Unavailability of the website	24-72 hours	✓ Unprofessional employee ✓ Non-targeted virus ✓ Competitor ✓ Script-kiddies ✓ Electricity failure ✓ Host	✓ Loss of credibility ✓ Loss of reputation ✓ Negative rumours spread	2. Limited
• Alteration of the website contents	Controlled	✓ Unprofessional employee ✓ Non-targeted virus ✓ Competitor ✓ Script-kiddies ✓ Host	✓ Loss of credibility ✓ Loss of reputation ✓ Negative rumours spread ✓ Loss of contract or customer	3. Important
• Compromising of the website contents	Public	-	-	1. Negligible

In a nutshell…

- **EBIOS does not protect you from risks, but it allows you to make your decision-makers aware.**

The EBIOS Risk Manager



What is the Ebios risk manager method?

WHAT IS THE EBIOS RISK MANAGER METHOD?

EBIOS Risk Manager[1] (EBIOS RM) is the method for assessing and treating digital risks published by National Cybersecurity Agency of France (ANSSI) with the support of Club EBIOS[2]. It proposes a toolbox that can be adapted, of which the use varies according to the objective of the project, and is compatible with the reference standards in effect, in terms of risk management[3] as well as in terms of cybersecurity[4].

EBIOS RM makes it possible to assess digital risks and to identify the security measures to be taken in order to control them. It also makes it possible to validate the acceptable level of risk and to carry on in the longer term in a continuous improvement approach. Finally, this method makes it possible to bring about resources and arguments that are useful for communication and decision-making within the organisation and with regards to its partners.

Use of the EBIOS RM Method

The EBIOS RM method can be used for several purposes:

- setting up or reinforcing a management process of the digital risk within an organisation;
- assess and treat the risks relating to a digital project, in particular with the aim of a security accreditation;
- define the level of security to be achieved for a product or service according to its use cases and the risks to be countered, in the perspective of a certification or accreditation for example.

Digital (numerique) risk management pyramid

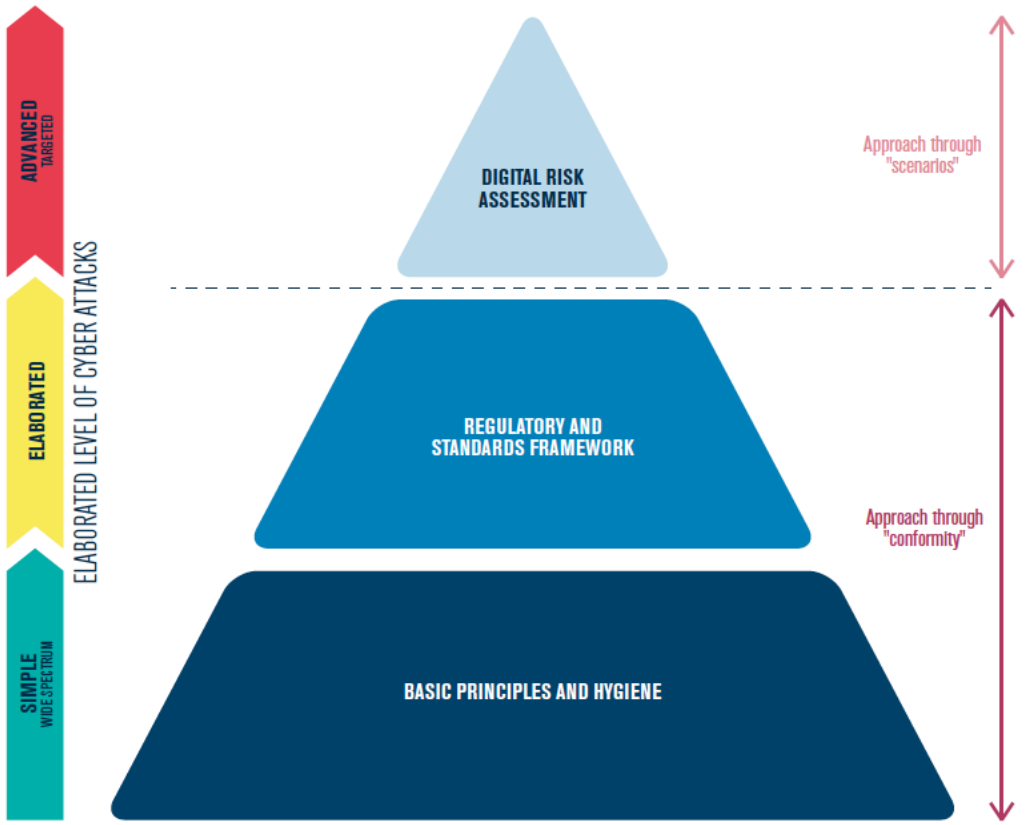
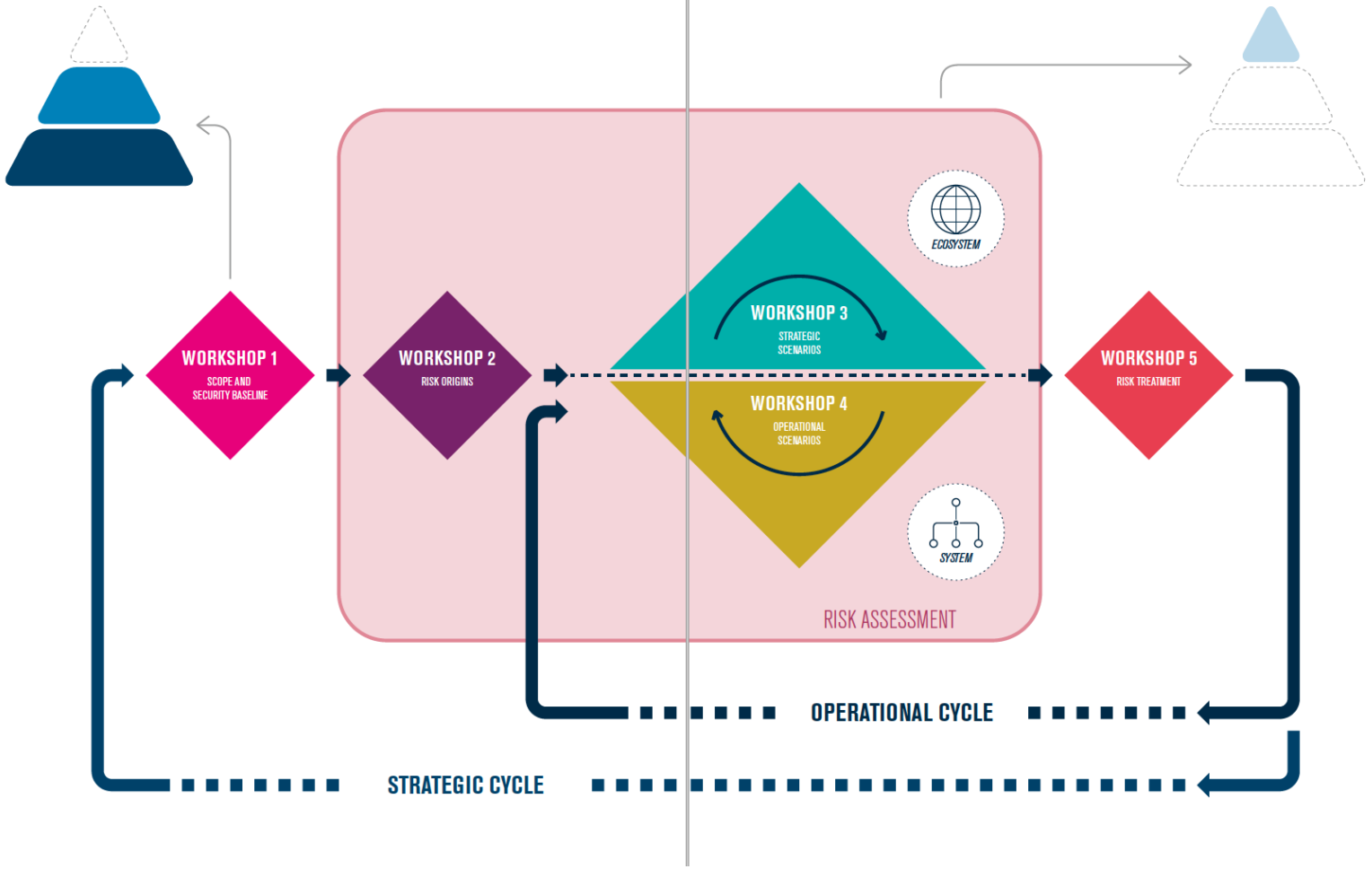


*Figure 1 — **Digital risk management pyramid***

An iterative approach that revolves around 5 workshops

THE EBIOS RM METHOD ADOPTS AN ITERATIVE APPROACH THAT REVOLVES AROUND FIVE WORKSHOPS.

*Figure 2 — **An iterative approach in 5 workshops***



WORKSHOP 1

Scope and security baseline

The first workshop aims to identify the studied object, the participants in the workshops and the timeframe. During this workshop, you will list the missions, business assets[5] and supporting assets related to the studied object. You identify the feared events associated with the business assets and assess the severity of their impacts. You also define the security baseline and the differencial.

NOTE: workshop 1 makes it possible to follow an approach by "compliance", corresponding to the first two stages of the digital risk management pyramid and to address the study from the "defence" viewpoint.

WORKSHOP 2

Risk origins

In the second workshop, you identify and characterise the risk origins (RO) and their high-level targets, called target objectives (TO). The RO/TO pairs deemed the most relevant are selected at the end of this workshop. The results are formalised in a mapping of the risk origins.

WORKSHOP 3

Strategic scenarios

In workshop 3, you will get a clear view of the ecosystem and establish a mapping of the digital threat of the latter with respect to the studied object. This will allow you to construct high-level scenarios, called strategic scenarios. They represent the attack paths that a risk origin is likely to take to reach its target. These scenarios are designed at the scale of the ecosystem and the business assets of the studied object. They are assessed in terms of severity. At the end of this workshop, you can already define the security measures on the ecosystem.

◆

WORKSHOP 4

Operational scenarios

The purpose of workshop 4 is to construct technical scenarios that include the methods of attack that are likely to be used by the risk origins to carry out the strategic scenarios. This workshop adopts an approach similar to the one of the preceding workshop but focuses on critical supporting assets. You then assess the level of likelihood of the operational scenarios obtained.

NOTES

- Workshops 3 and 4 are naturally supplied during successive iterations.
- Workshops 2, 3 and 4 make it possible to assess the risks, which constitutes the last stage of the digital risk management pyramid. They use the security baseline according to different attack paths, which are relevant with regards to the threats considered and as a limited number in order to facilitate the analysis.

WORKSHOP 5

Risk treatment

The last workshop consists in creating a summary of all of the risks studied in order to define a risk treatment strategy. The latter is then broken down into security measures written into a continuous improvement plan. During this workshop, you establish the summary of the residual risks and define the framework for monitoring risks.

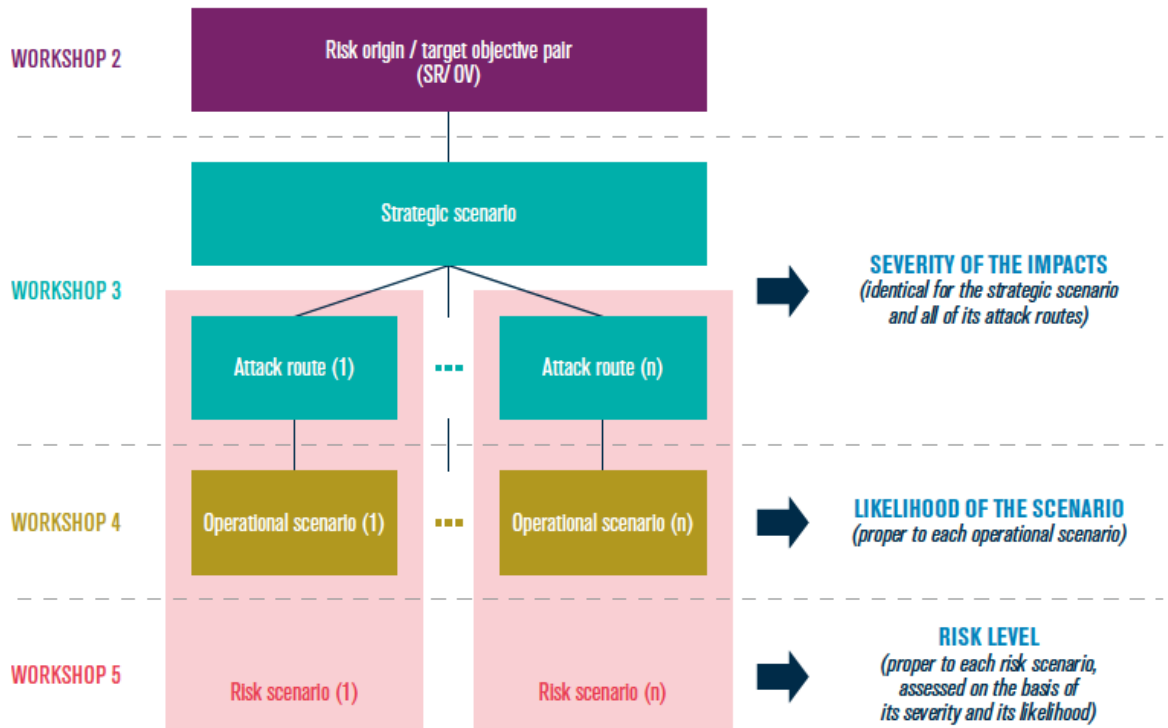


*Figure 3 — **Link between the various workshops***

EXAMPLE : Biotechnology company manufacturing vaccines.

MISSION	IDENTIFY AND MANUFACTURE VACCINES				
DENOMINATION OF THE BUSINESS ASSET	**Research & development (R&D)**			**Manufacturing vaccines**	**Traceability and control**
NATURE OF THE BUSINESS ASSET *(PROCESS OR INFORMATION)*	Process			Process	Information
DESCRIPTION	Vaccine research and development activity requiring: ■ the identification of antigens; ■ the production of antigens (attenuated live virus, inactivated virus): fermentation (harvest), purification, inactivation, filtration, storage; ■ preclinical assessment; ■ clinical development.			Activity consisting in : ■ filling syringes (sterilisation, filling; labelling); ■ conditioning (labelling and packaging).	Information enabling to ensure the quality control and the batch release (examples: antigen, aseptic distribution, conditioning, final release…)
ENTITY OR PERSON RESPONSIBLE *(INTERNAL/EXTERNAL)*	Pharmacist			Production manager	Quality Manager
DENOMINATION OF ASSOCIATED SUPPORTING ASSET(S)	Desktop application servers (internal)	Desktop application servers (external)	Antigen production systems	Production systems	Desktop application servers (internal)
DESCRIPTION	Desktop application servers storing all of the R&D data	Desktop application servers storing a portion of the R&D data	Set of IT equipment and machines that make it possible to produce antigens	Set of IT equipment and machines that make it possible to produce vaccines on a large scale	Desktop application servers storing all of the data regarding traceability and control, for the various processes
ENTITY OR PERSON RESPONSIBLE *(INTERNAL/EXTERNAL)*	IT department / Information management team	Laboratories	Laboratories	IT department / Information management team + Equipment suppliers	IT department / Information management team

Scoring of severity impacts

SCALE	CONSEQUENCES
G4 CRITICAL	Incapacity for the company to ensure all or a portion of its activity, with possible serious impacts on the safety of persons and assets. The company will most likely not overcome the situation (its survival is threatened).
G3 SERIOUS	High degradation in the performance of the activity, with possible significant impacts on the safety of persons and assets. The company will overcome the situation with serious difficulties (operation in a highly degraded mode).
G2 SIGNIFICANT	Degradation in the performance of the activity with no impact on the safety of persons and assets. The company will overcome the situation despite a few difficulties (operation in degraded mode).
G1 MINOR	No impact on operations or the performance of the activity or on the safety of persons and assets. The company will overcome the situation without too many difficulties (margins will be consumed).

Feared events

BUSINESS ASSET	FEARED EVENT	IMPACTS	SEVERITY
R&D	Loss or destruction of analyses and research information resulting in a high impact, in particular on the company's future marketing authorisation procedure	■ Impacts on the missions and services of the organisation ■ Impacts on the costs of development ■ Impacts on the organisation's governance	3
	Alteration of analyses and research information resulting in an erroneous vaccine formula	■ Impacts on the safety or on the health of persons ■ Impacts on the image and trust ■ Legal impacts	3
	Leaking of the company's analyses and research information	■ Impacts on the organisation's governance ■ Financial impacts	3
	Interruption of the vaccine test phases for more than one week	■ Impacts on the missions and services of the organisation ■ Financial impacts	2
Manufacturing vaccines	Leaking of the company's know-how regarding the process for manufacturing vaccines and their quality tests	Financial impacts	2
	Interruption of the vaccine production or distribution for more than one week during the peak of the epidemic	■ Impacts on the safety or on the health of persons ■ Impacts on the image and trust ■ Financial impacts	4
Traceability and control	Alteration of the quality control results leading to a sanitary non-compliance	■ Impacts on the safety or on the health of persons ■ Impacts on the image and trust ■ Legal impacts	4

Risk Assessment reference points

- ISO 31000
- ISO 27005
- OCTAVE – component driven
- NIST SP 800-30
- EBIOS
- Mehari
- CRAMM
- Magerit

Where can you find OCTAVE?

- OCTAVE Allegro, from 2008: Improving the Information Security Risk Assessment Process
- Created by the Carnegie Mellon University, Pittsburgh PA (same of CERT)



https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=8419

In a nutshell…OCTAVE

Carnegie-Mellon University, Pittsburgh, 1999

Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE)

OCTAVE is a methodology for identifying and evaluating information security risks. It is intended to help an organization to

- develop qualitative risk evaluation criteria that describe the organization's operational risk tolerances
- identify assets that are important to the mission of the organization
- identify vulnerabilities and threats to those assets
- determine and evaluate the potential consequences to the organization if threats are realized

In a nutshell…OCTAVE Allegro

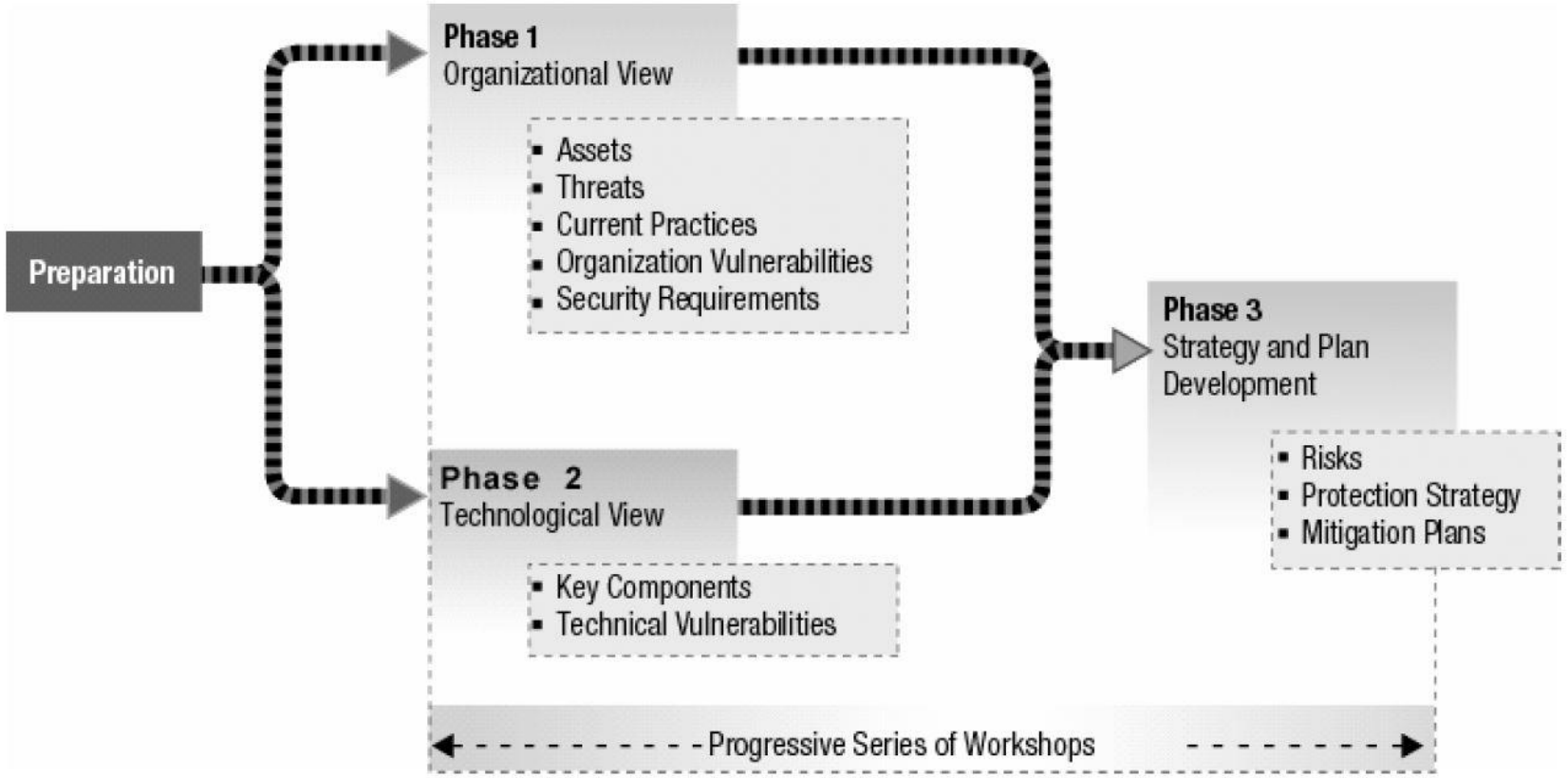
Carnegie-Mellon University, Pittsburgh, 1999 -> Allegro in 2008

Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE) - Allegro

OCTAVE Allegro is a methodology to streamline and optimize the process of assessing information security risks so that an organization can obtain sufficient results with a small investment in time, people, and other limited resources.

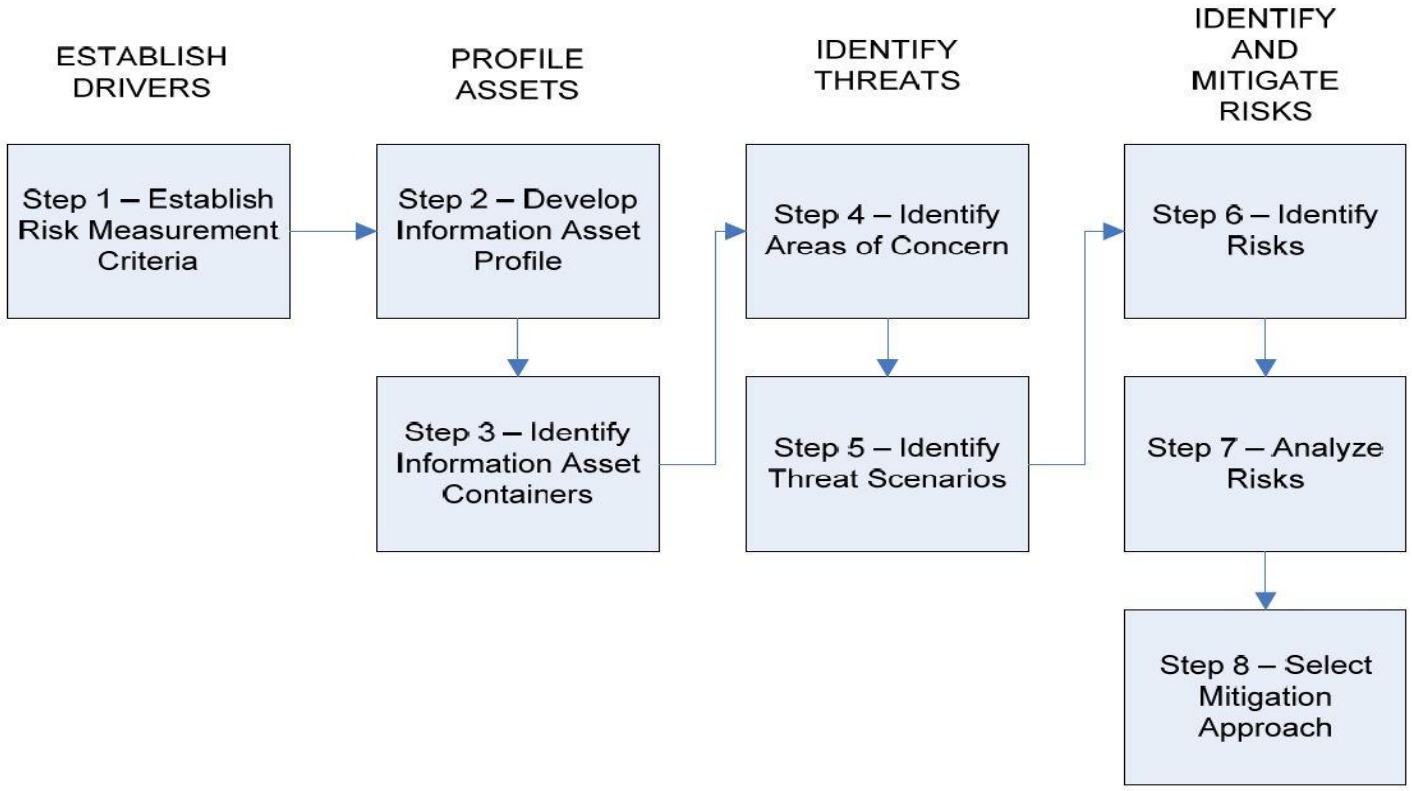
It leads the organization to consider people, technology, and facilities in the context of their relationship to information and the business processes and services they support.

OCTAVE in three phases



OCTAVE Allegro – simplified in 2008

- allegro: (al-leg-ro) *adv.* In a quick and lively tempo



Octave – Octave allegro

- Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE)

Step 1 – Establish Risk Measurement Criteria
Step 2 – Develop an Information Asset Profile
Step 3 – Identify Information Asset Containers
Step 4 – Identify Areas of Concern
Step 5 – Identify Threat Scenarios
Step 6 – Identify Risks
Step 7 – Analyze Risks
Step 8 – Select Mitigation Approach

The Allegro worksheets: reputation

Allegro Worksheet 1	Risk Measurement Criteria – Reputation and Customer Confidence		
Impact Area	Low	Moderate	**High**
Reputation	Reputation is minimally affected; little or no effort or expense is required to recover.	Reputation is damaged, and some effort and expense is required to recover.	**Reputation is irrevocably destroyed or damaged.**
Customer Loss	Less than _____% reduction in customers due to loss of confidence	_____to _____% reduction in customers due to loss of confidence	**More than _____% reduction in customers due to loss of confidence**
Other:			

The Allegro worksheets: financial

Allegro Worksheet 2	Risk Measurement Criteria – Financial		
Impact Area	Low	Moderate	**High**
Operating Costs	Increase of less than _____% in yearly operating costs	Yearly operating costs increase by _____to _____%.	**Yearly operating costs increase by more than _____%.**
Revenue Loss	Less than _____% yearly revenue loss	_____to _____% yearly revenue loss	**Greater than _____% yearly revenue loss**
One-Time Financial Loss	One-time financial cost of less than $_____	One-time financial cost of $_____ to $_____	**One-time financial cost greater than $_____**
Other:			

The Allegro worksheets: health and safety

Allegro Worksheet 4	Risk Measurement Criteria – Safety and Health		
Impact Area	Low	Moderate	**High**
Life	No loss or significant threat to customers' or staff members' lives	Customers' or staff members' lives are threatened, but they will recover after receiving medical treatment.	**Loss of customers' or staff members' lives**
Health	Minimal, immediately treatable degradation in customers' or staff members' health with recovery within four days	Temporary or recoverable impairment of customers' or staff members' health	**Permanent impairment of significant aspects of customers' or staff members' health**
Safety	Safety questioned	Safety affected	**Safety violated**
Other:			

The Allegro worksheets: Critical assets

Allegro Worksheet 8	CRITICAL INFORMATION ASSET PROFILE	
(1) Critical Asset **What is the critical information asset?**	(2) Rationale for Selection Why is this information asset important to the organization?	**(3) Description** **What is the agreed-upon description of this information asset?**
(4) Owner(s) **Who owns this information asset?**		
(5) Security Requirements **What are the security requirements for this information asset?**		
❑ **Confidentiality**	Only authorized personnel can view this information asset, as follows:	
❑ **Integrity**	Only authorized personnel can modify this information asset, as follows:	
❑ **Availability**	This asset must be available for these personnel to do their jobs, as follows:	
	This asset must be available for _____ hours, _____ days/week, _____ weeks/year.	
❑ **Other**	This asset has special regulatory compliance protection requirements, as follows:	
(6) Most Important Security Requirement **What is the most important security requirement for this information asset?**		
❑ **Confidentiality**	❑ **Integrity**	❑ **Availability** ❑ **Other**

The Allegro worksheets: Asset risk worksheet

Allegro - Worksheet 10		Information Asset Risk Worksheet			
Information Asset Risk	Threat	Information Asset			
		Area of Concern			
		(1) Actor Who would exploit the area of concern or threat?			
		(2) Means How would the actor do it? What would they do?			
		(3) Motive What is the actor's reason for doing it?			
		(4) Outcome What would be the resulting effect on the information asset?	❑ Disclosure ❑ Modification	❑ Destruction ❑ Interruption	
		(5) Security Requirements How would the information asset's security requirements be breached?			
		(6) Probability What is the likelihood that this threat scenario could occur?	❑ Medium	❑ Low	
	(7) Consequences What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?		(8) Severity How severe are these consequences to the organization or asset owner by impact area?		
			Impact Area	Value	Score

Relative risk score: mitigation

(9) Risk Mitigation Based on the total score for this risk, what action will you take?			
❑ Accept	❑ Defer	❑ Mitigate	❑ Transfer
For the risks that you decide to mitigate, perform the following:			
On what container would you apply controls?	What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?		

Threat scenario questionnaire 1: technical containers

Threat Scenario Questionnaire 1	Technical Containers		
This worksheet will help you to think about scenarios that could affect your information asset on the technical containers where it resides. These scenarios may pose risks that you will need to address. Consider each scenario and circle an appropriate response. If your answer is "yes" consider whether the scenario could occur accidentally or intentionally or both.			
Scenario 1: Think about the people who work in your organization. Is there a situation in which an employee could access one or more technical containers, accidentally or intentionally, causing your information asset to be:			
Disclosed to unauthorized individuals?	No	Yes (accidentally)	Yes (intentionally)
Modified so that it is not usable for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Interrupted so that it cannot be accessed for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Permanently destroyed or temporarily lost so that it cannot be used for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Scenario 2: Think about the people who are external to your organization. This could include people who may have a legitimate business relationship with your organization or not. Is there a situation where an outsider could access one or more technical containers, accidentally or intentionally, causing your information asset to be:			
Disclosed to unauthorized individuals?	No	Yes (accidentally)	Yes (intentionally)
Modified so that it is not usable for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Interrupted so that it cannot be accessed for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Permanently destroyed or temporarily lost so that it cannot be used for intended purposes?	No	Yes (accidentally)	Yes (intentionally)

Threat scenario questionnaire 2: physical containers

Threat Scenario Questionnaire – 2	Physical Containers		
This worksheet will help you to think about scenarios that could affect your information asset on the physical containers where it resides. These scenarios may pose risks that you will need to address. Consider each scenario and circle an appropriate response. If your answer is "yes" consider whether the scenario could occur accidentally or intentionally or both.			
Scenario 1: Think about the people who work in your organization. Is there a situation in which an employee could access one or more physical containers, accidentally or intentionally, causing your information asset to be:			
Disclosed to unauthorized individuals?	No	Yes (accidentally)	Yes (intentionally)
Modified so that it is not usable for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Interrupted so that it cannot be accessed for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Permanently destroyed or temporarily lost so that it cannot be used for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Scenario 2: Think about the people who are external to your organization. This could include people who may have a legitimate business relationship with your organization or not. Is there a situation in which an outsider could access one or more physical containers, accidentally or intentionally, causing your information asset to be:			
Disclosed to unauthorized individuals?	No	Yes (accidentally)	Yes (intentionally)
Modified so that it is not usable for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Interrupted so that it cannot be accessed for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Permanently destroyed or temporarily lost so that it cannot be used for intended purposes?	No	Yes (accidentally)	Yes (intentionally)

Threat scenario questionnaire 3: people

Threat Scenario Questionnaire – 3	People		
This worksheet will help you to think about scenarios that could affect your information asset because it is known by key personnel in the organization. These scenarios may pose risks that you will need to address. Consider each scenario and circle an appropriate response. If your answer is "yes" consider whether the scenario could occur accidentally or intentionally or both.			
Scenario 1: Think about the people who work in your organization. Is there a situation in which an employee has detailed knowledge of your information asset and could, accidentally or intentionally, cause the information asset to be:			
Disclosed to unauthorized individuals?	No	Yes (accidentally)	Yes (intentionally)
Modified so that it is not usable for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Interrupted so that it cannot be accessed for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Permanently destroyed or temporarily lost so that it cannot be used for intended purposes?	No	Yes (accidentally)	Yes (intentionally)
Scenario 2: Think about the people who are external to your organization. This could include people who may have a legitimate business relationship with your organization or not. Is there a situation in which an outsider could, accidentally or intentionally, cause your information asset to be:			
Disclosed to unauthorized individuals?	No	Yes (accidentally)	Yes (intentionally)

Thank you!

For information:

Indirizzo e-mail

cybersecurity_info@uniroma1.it
Stefano.zatti@uniroma1.it

Sito Web

https://cybersecurity.uniroma1.it